

Sality and the anatomy of a peer-to-peer takedown

The Sality P2P botnet, the actor CrowdStrike tracks as SALTY SPIDER, and the multinational disruption executed on 31 August 2026 — read for what it teaches about attacking decentralised overlays.

MACHINES REACHABLE

>15,000

payload-reachable at disruption, down roughly two orders of magnitude from peak

YEARS IN OPERATION

23

first public sample June 2003; RSA keys unchanged since at least 2011

DISJOINT NETWORKS

2

v3 and v4 — one codebase, one operator, incompatible protocols, different keys

AUTHOR

Douglas Mun, with AI assistance

PURPOSE

Technical baseline for a takedown-applicability assessment

CLASSIFICATION

TLP:CLEAR — public, unrestricted distribution

SOURCING

Primary: CrowdStrike Counter Adversary Operations, *Peer Pressure: Inside the Sality Botnet Disruption Operation*, 1 September 2026. Second primary source, independent of the vendor: U.S. Department of Justice, Central District of California, release 26-149, 1 September 2026.

Technical depth from Falliere, *Sality: Story of a Peer-to-Peer Viral Network* (Symantec, 2011); Rossow, Andriesse, Werner et al., *SoK: P2PWNEED* (IEEE S&P 2013); Kleissner, *Sality 2003–Today* (Botconf 2015); Dragos ICS research; open reporting.

Every judgement in this document carries its own confidence rating, defined in Section 1 and applied individually. There is no single overall confidence rating, because there should not be one.

CONTENTS

What is in this document

01	Analytic confidence lexicon	10	Precedent — the technique lineage
02	Key judgements	11	Actor profile — SALTY SPIDER
03	Timeline, 2003–2026	12	Protocol ossification
04	Host-side architecture	13	Disruption is not remediation
05	The peer-to-peer layer	14	Detection, hunting and remediation
06	The trust model — where the surface is	15	Applicability assessment
07	The disruption operation	16	Residual gaps
08	NAT, seizures and the tasking race	17	Source list
09	Scale and trajectory	—	26 exhibits, numbered throughout

EXECUTIVE SUMMARY

The technique is the story, not the botnet

On Monday 31 August 2026, CrowdStrike — working inside a coordinated law-enforcement operation with the DOJ, FBI, DCIS, Europol, Eurojust and national authorities in Bulgaria, Hungary and Romania — disrupted Sality, a peer-to-peer botnet that had run continuously since 2003. Two independent sources confirm the operation happened and describe its shape. Neither describes it as a decapitation of an active giant, and a write-up built on botnet size will not survive scrutiny.

What was disrupted was a long decline: something over 15,000 machines were reachable for payload delivery, against measured populations in the hundreds of thousands to low millions between 2011 and 2015. What makes the operation significant is architectural. Sality was rated *extremely resilient* in the peer-reviewed literature. It was taken apart without the operator's signing key, without access to a single victim machine, and by using the malware's own protocol against itself.

FINDING ONE

An authentication asymmetry, not a cryptographic break

Payload tasking was RSA-signed and unforgeable. Peer identity was not authenticated at all. The defender attacked the control plane and left the data plane alone.

FINDING TWO

The weakness was permanent by construction

A file infector cannot patch its installed population: a new strain competes with the old for the same host files. The RSA keys are byte-identical between 2011 and 2026 — verified here directly.

FINDING THREE

Disruption is quarantine, not cleanup

Every infected executable on every victim disk remains infected and active. File infection and lateral spread almost certainly continue, because sinkhole entries leave peer lists non-empty.

FINDING FOUR

Vendor attribution is not government attribution

CrowdStrike names SALTY SPIDER and places the actor in Bashkortostan, Russia. The DOJ release makes no attribution claim of any kind, and there is no charging document. Do not publish "Russia-attributed" as a government finding.

THE ONE LINE TO TAKE AWAY

Attack the unauthenticated control-plane topology of a decentralised overlay, not its authenticated command payloads — by controlling who bots believe they should talk to, the defender never needs the operator's key.

WHAT TO DO ABOUT IT

- 01 Alert on UDP traffic to 188.166.101.148. Any hit is a confirmed infection requiring remediation.
- 02 Deploy both published YARA rules against *running processes*, not files on disk.
- 03 Treat every infected host as still spreading to mapped drives, shares and removable media — the symptoms are now quieter, not absent.
- 04 Where EDR cannot run, pre-create the uxJLpe1m mutex as a compensating control. Test before fleet deployment.
- 05 Defer any regional exposure claim: the usable geography is eleven years old. Obtain CrowdStrike's infection-geography breakdown first.
- 06 Confirm victim-notification reach with SingCERT or your national CSIRT rather than assuming the Shadowserver pathway lands locally.

SECTION 01

Analytic confidence lexicon

Defined once, here, and applied per judgement everywhere else. Confidence expresses *how much weight the evidence and reasoning bear*. It is not a probability that an event will occur, and it is not a measure of how strongly the analyst feels. A single overall rating for a whole report is not usable — attribution may rest on thin ground while the technical characterisation is solid.

EXHIBIT 1

Three levels, and what each one licenses

High Primary or independently verifiable evidence. The inferential chain is short. Credible alternatives examined and set aside. New information would refine rather than overturn. CAN CARRY A DECISION	Moderate Credible but incomplete — single-sourced, partially corroborated, dated, or reached through several inferential steps. Alternatives remain open. New information could reasonably shift it. CARRIES A DECISION WITH HEDGES	Low Fragmentary, uncorroborated, dated or interested reporting, or a long chain of inference. Recorded because the question is decision-relevant, not because the answer is secure. MUST NOT CARRY A DECISION ALONE
---	--	--

Source: analytic standard applied in this document. Confidence and likelihood are orthogonal; likelihood uses a separate vocabulary — almost certainly, highly likely, likely, realistic possibility, unlikely, highly unlikely.

1.2 Rules of application

- Confidence is not likelihood.** One can hold high confidence that something is unlikely.
- Confidence is not source count.** Ten outlets recycling one wire story are one source. Corroboration requires independent origin, not repetition.
- Confidence is not conviction.** Analyst certainty is not evidence.
- Interested sourcing caps confidence.** A vendor's account of its own operation is primary for *what was done* and weaker for *how well it worked*.
- Split compound judgements.** Where an event and its interpretation carry different evidential weight, they are rated separately.
- Age degrades confidence.** Technical facts about a 2011 protocol version do not automatically hold in 2026 unless continuity is separately evidenced.

1.3 Statement-type tags

[F] Fact	[A] Assessment	[X] Assumption
Directly evidenced and attributable to a named source, or independently verifiable.	Analyst judgement extending beyond what the evidence states.	Accepted without direct evidence and load-bearing. If it fails, dependent judgements fail with it.

1.4 Load-bearing assumptions in this document

#	ASSUMPTION	IF IT FAILS
X-1	CrowdStrike's account of its own operation is accurate and complete in outline, even where it withholds specifics.	Sections 6, 7 and 8 and all operational conclusions become unreliable. Partially discharged: the DOJ release independently corroborates the fact and shape of the operation — execution on Monday 31 August; a peer-to-peer sinkhole operation; domain seizures in the US and in Bulgaria, Hungary and Romania; Europol and Eurojust participation; Shadowserver's victim-notification role. Undischarged for mechanics, scale and effect: DOJ states no infection count, no technical mechanism, no financial figures, and makes no completeness claim.
X-2	Protocol behaviour documented by Falliere in 2011 still describes the code live in August 2026.	Section 3, Section 4 and the detection logic in 14.4 degrade. Partially discharged: the frozen RSA keys (12.1) and the IPFILTERDRIVER string in the 2026 YARA rules both evidence continuity, and CrowdStrike's description of the 40-minute cycle and peer-list semantics matches Falliere.
X-3	The ~15,000 figure and the historical population figures measure comparable populations.	Section 9 magnitude claims fail. This assumption is known to be weak and is treated as such throughout.

SECTION 02

Key judgements

Thirteen judgements, rated individually. Where an occurrence and its interpretation carry different evidential weight they are split — KJ-6, KJ-8 and KJ-9 each appear as lettered pairs for that reason. The table runs over three pages; the column headings repeat on each.

KEY JUDGEMENTS (1 OF 3)

#	JUDGEMENT	TYPE	CONFIDENCE
KJ-1	Target is Sality , operated by SALTY SPIDER . Two disjoint P2P networks, v3 and v4 , live at disruption — same codebase, same operator, incompatible protocols, different keys.	[F]	HIGH
KJ-2	Layered disruption , not a single technique: P2P sinkholing via peer-list manipulation <i>plus</i> coordinated payload-URL takedown, the latter explicitly covering the transition period.	[F]	HIGH Corroborated by DOJ, which independently describes a P2P sinkhole operation alongside domain seizures
KJ-3	The exploited weakness is an authentication asymmetry : payload tasking RSA-signed and unforgeable; peer identity not authenticated at all.	[F]	HIGH Stated by CrowdStrike, independently corroborated by Falliere (2011) and P2PWED (2013)
KJ-4	Generalisable technique: <i>attack the unauthenticated control-plane topology of a decentralised overlay, not its authenticated command payloads</i> . The specific Sality primitive is not portable.	[A]	MODERATE Sound abstraction, and CrowdStrike places Sality in the GameOver Zeus / Kelihos lineage, but transferability to any named future target is untested
KJ-5	Protocol ossification . A file infector cannot be patched without the new strain competing with the old for the same host files, fragmenting rather than upgrading the botnet. Weaknesses are therefore permanent.	[A]	HIGH Two independent lines: CrowdStrike's assertion, and the frozen RSA keys at KJ-9

KEY JUDGEMENTS · CONTINUED (2 OF 3)

#	JUDGEMENT	TYPE	CONFIDENCE
KJ-6a	The botnet declined very substantially between its 2011–2015 peak and 2026.	[A]	HIGH Every available baseline shows the same direction
KJ-6b	The decline is specifically ~95–99% .	[A]	LOW Baselines are not methodologically comparable. Range varies by baseline chosen — see Section 9
KJ-7	Disruption is not remediation. Infected executables persist and remain active. Network quarantine at botnet scale.	[F]	HIGH Stated explicitly by CrowdStrike
KJ-8a	The three DDoS campaigns (Apr 2016, Feb 2022, Sep 2023) occurred as described .	[F]	MODERATE Single-sourced to CrowdStrike, no independent corroboration located
KJ-8b	The Feb 2022 Kharkiv attack was patriotically motivated ; the Sep 2023 attack was impulsive personal grievance .	[A]	LOW–MODERATE CrowdStrike's own hedged assessments, not findings — their language is "likely aligned" and "suggesting"
KJ-8c	Counter-attack risk against sinkhole infrastructure is real.	[A]	MODERATE Rests on Kleissner's independently sourced 2014–15 record of four DDoS attacks on a Sality sinkhole operator

KEY JUDGEMENTS · CONTINUED (3 OF 3)

#	JUDGEMENT	TYPE	CONFIDENCE
KJ-9a	The v3 and v4 RSA public keys are byte-identical between Falliere's July 2011 publication and CrowdStrike's August 2026 YARA rules.	[F]	HIGH Independently verified by direct byte comparison (12.1)
KJ-9b	This demonstrates the operator could not rotate keys , because a new key means a new network.	[A]	MODERATE-HIGH Mechanism explained by Falliere in 2011 and consistent with KJ-5; the alternative — chose not to rotate — cannot be fully excluded
KJ-10	File infection and lateral spread almost certainly continue post-disruption, because sinkhole entries leave peer lists non-empty.	[A]	MODERATE See 8.4. The operational recommendation is robust either way
KJ-11	The exact eviction primitive remains undisclosed ; the P2PWNEED port-overwrite hypothesis is inference, not fact.	[F]/ [A]	HIGH that it is undisclosed LOW that the hypothesis identifies what was used (6.3)
KJ-12	Vendor and government attribution diverge. CrowdStrike names SALTY SPIDER and places the actor in Bashkortostan, Russia. The DOJ release makes no attribution claim of any kind.	[F]	HIGH Verifiable by reading both documents. Do not present "Russia-attributed" as a government finding
KJ-13	There is no visible prosecution track . No charges, no indictment, no named defendant, no forfeiture, no sanctions. The operation was disruption-only.	[F]	HIGH Contrast Qakbot, same US Attorney's Office, which carried an \$8.6M seizure and a later indictment

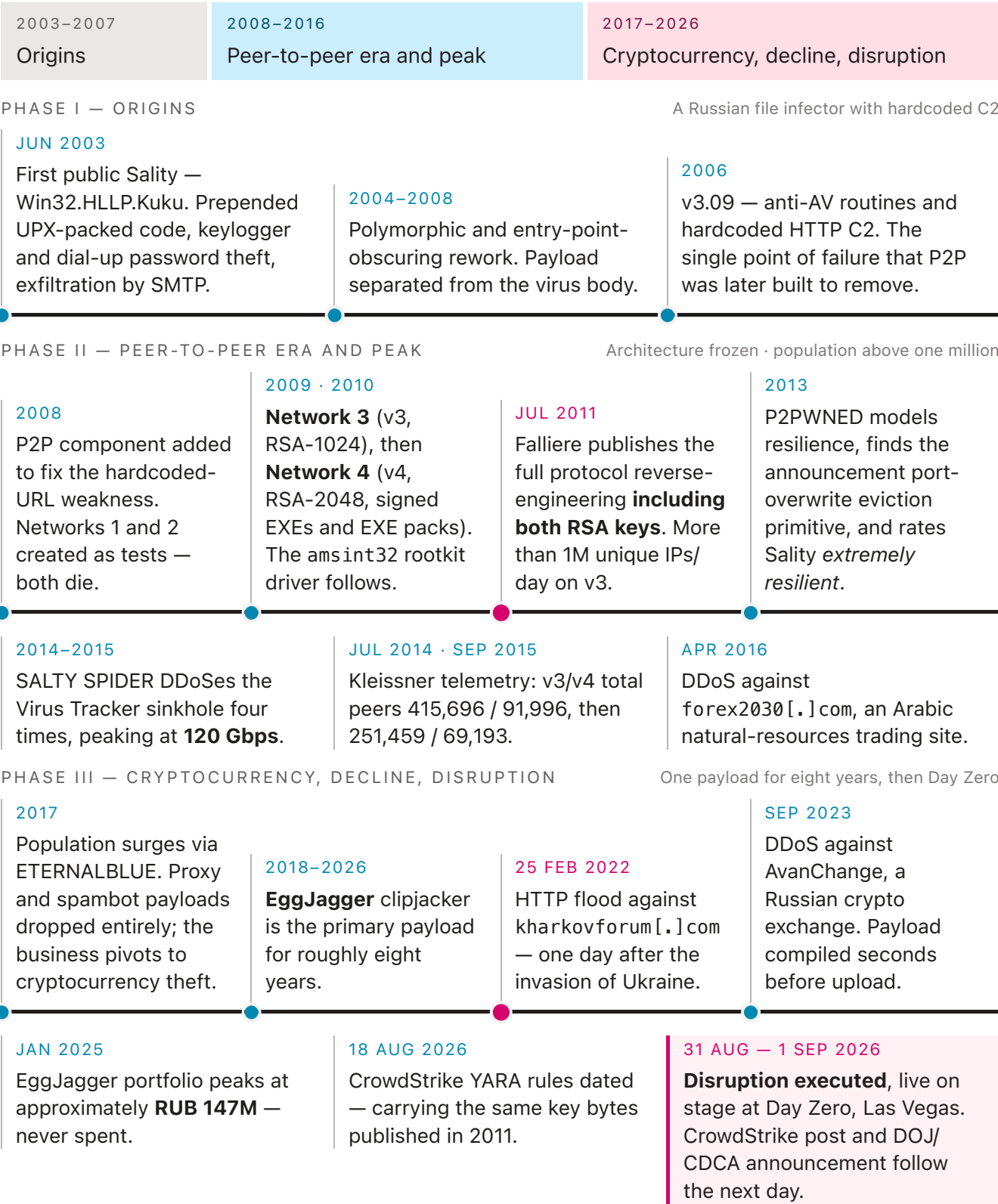
SECTION 03

Timeline, 2003 to 2026

Twenty-three years in three phases. The shape that matters is the middle one: every architectural decision that made Sality durable was taken between 2008 and 2010, and none of it could be revised afterwards.

EXHIBIT 2

Three phases of one continuously operated botnet



Phased, not linearly scaled — the era ribbon at the top carries the proportional span. Sources: Falliere 2011; P2PWNEED 2013; Kleissner 2015; CrowdStrike 2019 and 2026; DOJ/CDCA release 26-149. Magenta markers denote the four events that determine the takedown's feasibility.

NOTE ON KEY CONTINUITY

Direct evidence establishes the keys were unchanged between July 2011 and August 2026 **[F, High]**. That they were *a/so* unchanged from network creation in 2009/2010 is an inference from Falliere's finding that a new protocol version implies a new embedded key **[A, Moderate]**.

SECTION 04

Host-side architecture

Falliere describes recent Sality as semi-independent components running in separate threads. Each one has a distinct defensive consequence, and three of them explain why single-process termination, Safe Mode recovery and antivirus updating all fail on an infected host.

EXHIBIT 3

Five components, five defensive consequences

01 Injector	02 Protector	03 Infector	04 Downloader	05 P2P component
Injects into every process except system, local service, network service. Kill one instance and an injected process takes over.	Deletes the SafeBoot keys, disables AV and firewall services, drops the amsint32 kernel driver.	Infects .exe and .scr on drives B: to Z:, network shares and removable media. Destroys security binaries.	Fetches and executes the payloads named in the current URL pack. RC4-decrypts with a static key from the virus body.	Client and server threads, a 40-minute cycle, a local peer list. This is the layer the takedown attacked.
Termination is not remediation	Safe Mode may be unavailable	USB and SMB spread continues	Cached tasking survives isolation	No peer identity to authenticate

Source: Falliere, Symantec 2011, corroborated in outline by CrowdStrike 2026. [F, High]

4.1 Injector

Injects into all running processes except those under system, local service and network service. If privileged, it grants itself SeDebugPrivilege and retries. If one instance is killed, an injected process takes over — **single-process termination does not remediate**. Per-process mutexes named <ProcessName>M_<PID>_ prevent double-injection; many of these on a live host is a strong infection indicator. [F, High]

4.2 Protector

- Deletes SafeBoot subkeys under both HKCU and HKLM\System\CurrentControlSet\Control\SafeBoot — blocking Safe Mode recovery.

- Stops and disables a long hardcoded list of AV and firewall services.
- Drops a kernel driver to a pseudo-random name in %System%\drivers, registered as service **amsint32** — the service name is stable across variants — creating \Device\amsint32. Some variants drop the driver as amsint32.sys directly.

DRIVER FUNCTION 1

Process killer. Terminates matched security processes from kernel mode via NtTerminateProcess.

DRIVER FUNCTION 2

Packet filter. Registers an IPFilter callback via IOCTL_PF_SET_EXTENSION_POINTER and drops packets containing security-vendor strings — symantec., kaspersky, virustotal., sality-remov and around twenty more.

DRIVER FUNCTION 3

SMTP blocking. Botmaster-enableable; the code remains in later variants but is unreachable.

CONTINUITY EVIDENCE

CrowdStrike's 2026 YARA rules include the string IPFILTERDRIVER as a required condition. The packet-filtering mechanism Falliere documented in 2011 was present in samples live at disruption. **[F, High]** — this materially discharges assumption X-2.

COMPLIANCE CONSEQUENCE — SCOPE CAREFULLY

Dragos flagged that because Sality blocks outbound AV connections, antivirus cannot update, breaching **NERC CIP-007-6**. NERC CIP is a North American bulk-electric-system standard and **does not apply in Singapore**. Cite it as illustrating the *class* of consequence; the local analogue for CII operators is the Cybersecurity Act and the sector Codes of Practice. **[F]** for the Dragos finding; **[A, Moderate]** that an equivalent finding arises under SG CII obligations.

4.3 Infector

Infection targets, in order of preference:

- 1 Files under HKCU\Software\Microsoft\Windows\ShellNoRoam\MUICache — an effective installed-app inventory
- 2 Files under both Run keys, HKCU and HKLM
- 3 All .exe and .scr on all mapped drives **B: through Z:**
- 4 Root folders of non-Windows drives — drops an infected Calculator or Minesweeper copy under a random .exe/.cmd/.pif name and writes or modifies autorun.inf. **The USB and external-drive vector.**
- 5 All executables found by enumerating network resources

Security-software files are instead **destroyed** — the entry point is overwritten with

CC C3 CC C3 CC C3 CC C3 (int 3 / ret) — or deleted. .vdb and .avc definition files are hunted and deleted. **[F, High]**

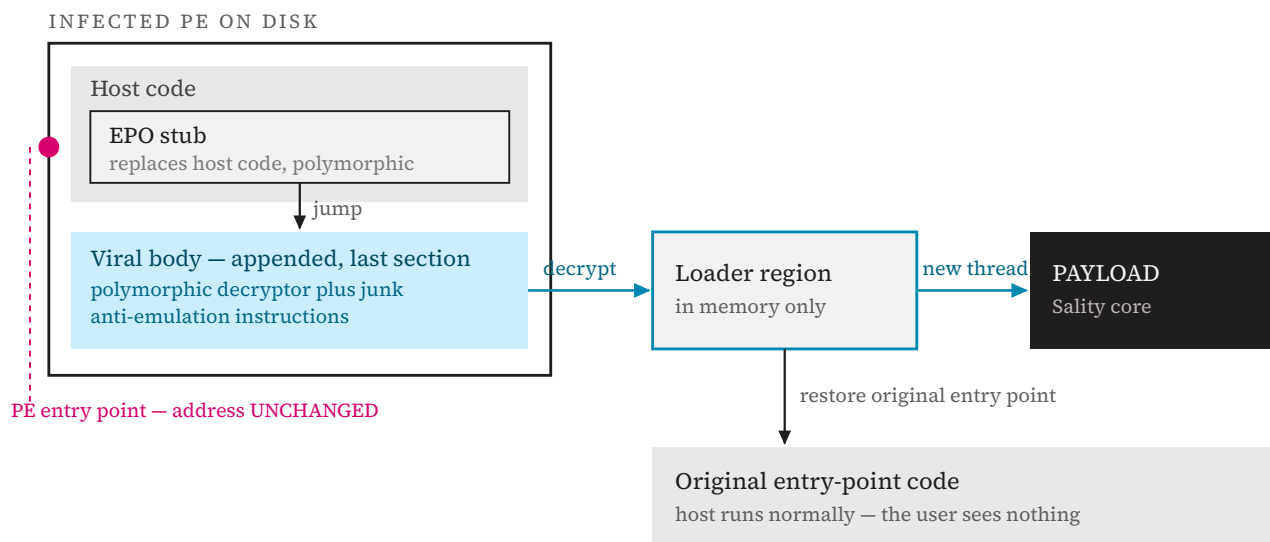
The behavioural detail with direct takedown consequences: all infection routines are disabled *if the peer list is empty*. See 8.4 — this is the hinge of the propagation question.

4.4 Execution flow of an infected file

The entry-point *address* is unchanged; the *code* at the entry point is replaced by a variable stub from Sality's polymorphic generator, self-labelled "*Simple Poly Engine v1.1a (c) Sector*". This is why file-based scanning underperforms and memory scanning works.

EXHIBIT 4

Falliere Figure 4, reconstructed — the host runs normally and the user sees nothing



Reconstructed from the technical description in Falliere 2011, original figure numbering preserved for cross-reference. **[F, High]** for the mechanism.

SCOPING CAUTION

The figures often quoted for this mechanism — "122 bytes replaced, original stashed 1,422 bytes from the start of the last section" — come from F-Secure's write-up of **W32/Sality.Q specifically** and must not be generalised to the family. Falliere describes the mechanism without fixed byte counts, and the stub is polymorphic by design. **[F, High]** for the mechanism; the byte counts are variant-specific.

Global mutex **uxJLpe1m** synchronises instances and is unique across variants (Falliere). Kleissner separately records `purity_control_4428` and `kukuttrusted!`

as run-check mutexes in the variants he analysed — treat all three as candidate indicators rather than assuming one canonical value. **[F, High]** for the first; **[F, Moderate]** for the others.

BOTH THE BEST HOST IOC AND AN INOCULATION VECTOR

Falliere notes that *pre-creating* the uxJLpe1m mutex prevents infection. For legacy or OT estate that cannot run EDR, a startup task holding this mutex is a cheap compensating control. **[A, Moderate]** that this still works against 2026 variants — the mechanism is unchanged in principle but untested by us. Test before fleet deployment.

SECTION 05

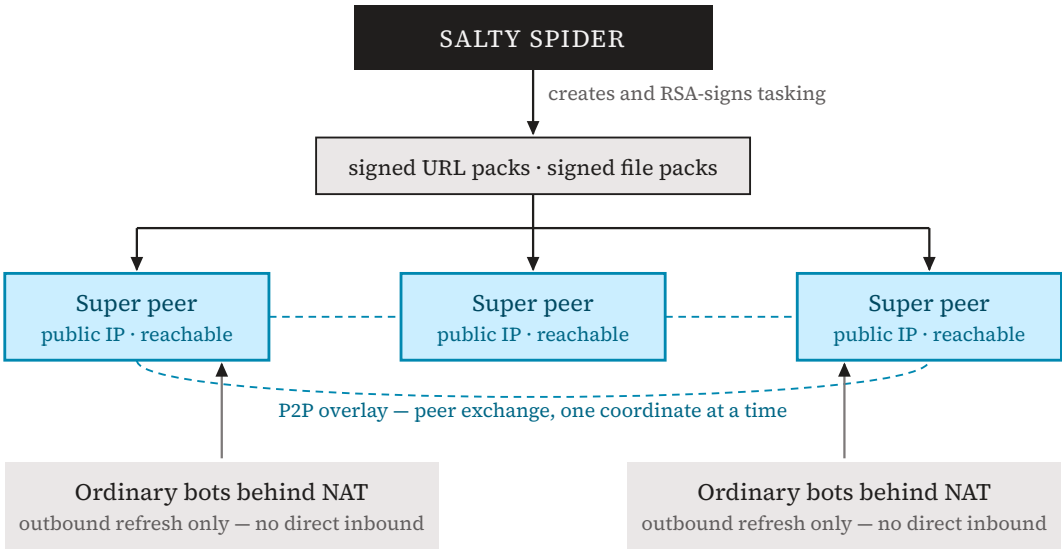
The peer-to-peer layer

Each infected host starts two threads: a *client* thread that queries peers, and a *server* thread listening on a UDP port derived from the computer name. Reachable from the internet, a host is promotable to **super peer**. Behind NAT or a firewall, the server thread is useless and the host stays a **simple peer**.

5.1 Topology — super peers and ordinary peers

EXHIBIT 5

The overlay is a delivery fabric with a small reachable backbone



Reconstructed from Falliere 2011 and CrowdStrike 2026. P2PWNEED measured only 36.9% (v3) and 40.0% (v4) of enumerated peers as routable — the backbone is a minority of the population, which is why it was targeted first.

PEER ID	MEANING
0	Not promoted — keeps sending Announcement & Promotion queries
< 16,000,000	Low peer ID — not externally reachable
≥ 16,000,000	Super peer — added to other bots' peer lists

Studied variants return 0 rather than a low ID, making clients **inherently aggressive about becoming super peers**. That aggression is precisely what lets

a defender-controlled reachable node get promoted and adopted. **[F, High]**

5.2 The peer list and goodcount

Goodcount is the anti-poisoning control, and it is strictly local: never exchanged over the network, never stored in bootstrap lists. An attacker cannot claim a reputation — which is why the eviction primitive matters so much (6.3): it bypasses goodcount rather than beating it.

EXHIBIT 6

The reputation loop, and the six mechanics that bound it

LOCAL PEER LIST

Peer A	+ + +
Peer B	+ +
Peer C	-
Peer D	+ + +

EVERY ~40 MINUTES — PROBE KNOWN PEERS

Valid response
improve reputation

Failure or malformed
degrade reputation

Sustained failure → eventual peer removal

MECHANICS

- 01 **Bootstrap list** embedded in every infected file, maximum **1,000 entries**. When Sality infects a file it embeds its current local list — the bootstrap list travels with the infection.
- 02 **Local list** stored in the registry under a username-seeded pseudo-random HKCU key, adding last-contact time, goodcount and PeerID.
- 03 **Goodcount** incremented on a protocol-conformant reply, decremented otherwise.
- 04 **Never exchanged, never stored** in bootstrap lists. Strictly local — the anti-poisoning control.
- 05 **Cleanup**: discard entries below -30, but only if the list holds **≥ 500** peers.
- 06 **Peer Exchange** requested when the list holds **< 980** entries (older builds: as low as 200), and it returns **exactly one** peer, chosen at random from entries with strictly positive goodcount.

Source: Falliere 2011, confirmed in outline by CrowdStrike 2026. [F, High]

5.3 Transport and packet format

The server thread's port is derived from the computer name. One implementation Falliere observed: if the name is shorter than two characters the port is 9674; otherwise $\text{Port} = 2199 + \text{name}[\text{last}] \times \text{name}[\text{first}]$.

EXHIBIT 7

Port range, packet layout, and why any sensor can decrypt the traffic

MINIMUM 4,224 2199 + 45×45	MAXIMUM 17,083 2199 + 122×122	UPPERCASE NAMES 4,224–10,299 narrower subrange	DISTINCT PORTS 1,751 across the Windows charset
---	--	---	--

UDP PAYLOAD

WORD h hash 0x00	WORD n size 0x02	BYTE[n] — RC4(data) n = packet length - 4 0x04
---	---	---

RC4 key k = MAKE_DWORD(h, n)

the first four bytes of the packet ARE the key

DECRYPTED DATA

BYTE Version	DWORD URL Pack Sequence ID	BYTE Command	BYTE[m] Content (m = n - 6)
------------------------------------	--	------------------------------------	---

Source: Falliere 2011. The constants C and f are implementation-specific — treat the port range as indicative, not exhaustive. Note that 9674 is also reachable via the formula, so it does not reliably identify the short-name fallback case.

TWO DISTINCT RC4 KEYS — DO NOT CONFLATE

The **P2P packet** key is derived per-packet from the header. The **downloaded payload** key is a static string hardcoded in the virus body: kukutruste d! . in older versions, GdiPlus.dll in newer ones. Kleissner independently observed GdiPlus.dll applied in 1,024-byte blocks. **[F, High]**

DETECTION VALUE

Because the packet key derives from the packet's own first four bytes, **any sensor can decrypt Sality traffic with no secret material**. Version and command then sit at fixed offsets. **[F, High]** for the mechanism; **[A, Moderate]** that signatures built this way would have caught 2026 traffic unmodified — the port formula constants are implementation-specific.

5.4 Protocol commands

In conceptual form the entire protocol is three sentences: *"Do you have a newer URL pack?"* · *"Here is my URL pack."* · *"Tell me another peer IP and port."* That is the whole vocabulary — which is both why it survived twenty-three years and why it had so little surface to defend.

CMD	NAME	FUNCTION
1	Announcement & Promotion	Peer advertises its UDP port . The IP is <i>not</i> sent — the server derives it from the packet source. The server probes back; on success the peer gets a High Peer ID.
2	Peer Exchange	Exchanges one super-peer coordinate at a time. The whole peer list can never transfer at once.
3	Pack Exchange	Compares URL Pack Sequence IDs; the higher wins and is transferred.

5.5 URL pack structure

EXHIBIT 8

Tasking is replay-immune and forge-immune — this half of the design held

Digital signature blob
RSA-1024 (v3) / RSA-2048 (v4), MD5, e = 65537

Sequence ID inside the signed data	Flags	URL count
http://<compromised-site>/logo.gif http://<compromised-site>/bottom.gif ...		

INSTALL RULES

Signature **must** verify

AND

Sequence ID strictly **greater** than current

Together these make the tasking channel **replay-immune and forge-immune**. No defender attack was ever available here.

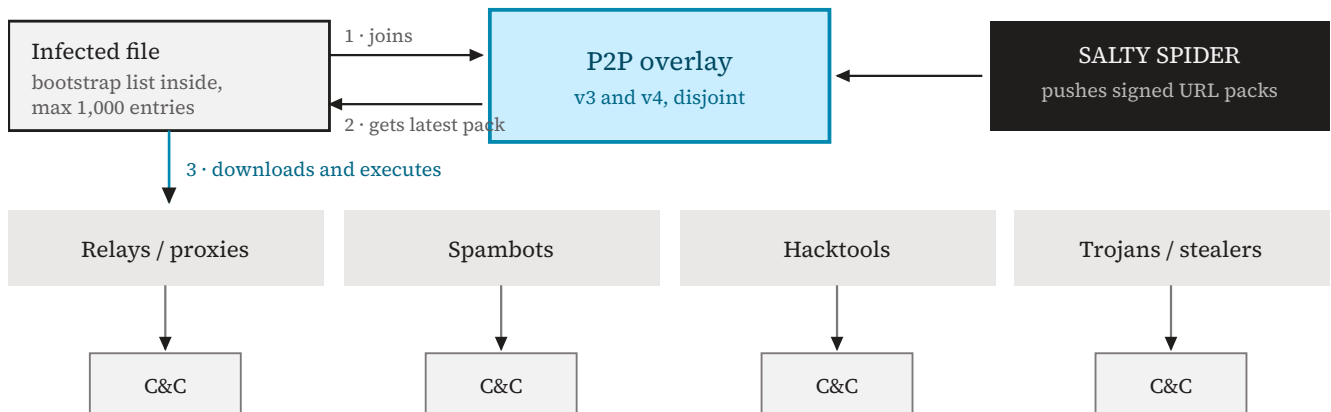
Source: Falliere 2011. In v4 the URL-fetched executables are themselves signed, with the signature following the ASCII marker e#o203kjL, ! and verified before execution.

5.6 The distribution scheme

The Sality P2P layer is only a **delivery fabric**. CrowdStrike states that Sality's sole technical capability was deploying additional payloads — and the secondary malware it delivered used conventional, centralised C2.

EXHIBIT 9

Falliere Figure 6, reconstructed — a delivery fabric feeding conventional botnets



Secondary malware uses conventional, centralised C2 — it does not inherit Sality's resilience.

Historical payloads: spam generators and relays, HTTP proxies, information stealers with IE injection, a website infector stealing FTP credentials to inject IFRAMES, a distributed SIP/VoIP cracker (Feb 2011), DDoS modules, experimental Facebook app registration. For the last eight years: EggJagger.

Reconstructed from Falliere 2011; payload summary corroborated by CrowdStrike 2026 (credential theft, spam, proxy services, network exploitation, DDoS). Falliere assessed the delivered malware shares a code signature with Sality itself and inferred the same gang wrote it — note the plural, which bears on 11.1. [A, Moderate].

5.7 The v3 client-thread cycle

This is the single most important exhibit in the document. Every forty minutes, each bot walks this ladder for each peer in its list. CrowdStrike's description of the operation maps directly onto it. **[F, High]**

EXHIBIT 10

Falliere Figure 10, reconstructed — the 40-minute loop is the attack surface

Spine on the left is the sequential path; the right column is what happens when a decision branches.



Reconstructed from Falliere 2011, Figure 10. Note that the *server* thread never modifies goodcounts — only the client thread does — which is why spoofing malformed packets from known-good peers to tank their reputation does not work.

5.8 What v4 added

EXHIBIT 11

Falliere Figure 11, reconstructed — EXE pack exchange, and the transport split

Identical to v3 up to the goodcount, Peer ID and Peer Exchange logic. The addition triggers when URL Pack exchange returns the *same* Sequence ID: the client then asks for the peer's EXE Pack Sequence ID.

Peer has a <i>newer</i> EXE pack?	YES → get it from the server over TCP
Peer has an <i>older</i> EXE pack?	YES → give own EXE pack to the server over TCP

EXE PACK STRUCTURE

Size and CRC
Digital signature
Sequence ID
Number of executables
Encrypted executables

TRANSPORT

- UDP Signalling, on port **P**
- TCP Bulk data, on port **P + 19**

If P+19 is already in use by another process, EXE pack delivery **silently fails**.

CrowdStrike's terminology is "file packs" for what Falliere called EXE packs, and confirms both channels stop once bots are isolated. Also new in v4: RSA raised to 2048 bits, and URL-fetched executables signed with the marker e#o203kj l, !. [F, High]

SECTION 06

The trust model — where the attack surface is

CrowdStrike's framing: bots trusted the network without verifying who was in it. Any publicly reachable machine that answered the handshake correctly was accepted — no authentication, no cryptographic identity, no allowlist. The sole requirement was availability, which made a defender node indistinguishable from a genuinely infected one. **[F, High]**

EXHIBIT 12

One row is authenticated. Three are not. The takedown lives in the fourth.

WHAT SALITY TRUSTS	AUTHENTICATED?	CONSEQUENCE
Payload and tasking	YES — RSA SIGNED	Unforgeable. No defender attack was ever available here.
Peer identity	NO	Anyone answering the handshake is a peer.
Peer discovery	NO	Peers propagate coordinates they were told, not coordinates they verified.
Peer-list updates	VULNERABLE	The exploited row. Remote behaviour can mutate an existing entry — see 6.3.

Confirmed by the primary source. Independently corroborated by Falliere 2011 and P2PWNEED 2013. **[F, High]**

6.1 v3 versus v4 — the signing evolution

EXHIBIT 13

v4 closed three holes and left the fourth open

	v3 2009	v4 2010
URL pack signed?	Yes — RSA-1024	Yes — RSA-2048
Payload executable signed?	No — fatal in v3	Yes — marker e#o203kjl, !
Direct executable transfer?	No	Yes — signed file packs over TCP
Peer identity signed?	No	No — still the hole

Source: Falliere 2011. The common claim that "Sality's payload channel is unauthenticated" is true of v3 only — scope any such statement to v3. Kleissner's 2015 observation that payloads were merely RC4'd with no certificate, so anyone re-registering an expired C2 domain could push executables, describes the v3 condition. [F, High]

6.2 Falliere's 2011 predictions — both came true

ON V3'S EXTERNAL WEAKNESS

An entity able to take control of the DNS entries in a URL pack and replace the executable could take control of the whole botnet.

→ the law-enforcement domain-seizure component of 2026

ON V4

No obvious way to destabilise or take control; another approach, outside that paper's scope, may involve a cluster of rogue super peers.

→ what CrowdStrike built, fifteen years later

[F, High] that Falliere wrote this. [A, Moderate] that it constitutes prediction rather than coincidence — the space of possible attacks on a P2P overlay is small, and both observations follow from the architecture.

6.3 The eviction primitive — still undisclosed

This is the one substantive gap the primary source does not close. [F, High] CrowdStrike's entire technical statement on the mechanism is that protocol-level manipulation during peer verification allows legitimate super-peer entries to be invalidated. No packet field, no state-machine edge case, no request/response sequence. The withholding is deliberate and reasonable — publishing it would hand the same primitive to anyone wanting to hijack rather than sinkhole the network.

The strongest published candidate reconciles two sources that look contradictory but are not: Falliere frames a behaviour as a *defence*, and P2PWNER frames the identical behaviour as an *attack*.

EXHIBIT 14

The asymmetry between the two commands — one respects goodcount, one bypasses it

PEER EXCHANGE CMD 2 Send (good IP, junk port) The old port is kept. The entry survives. Goodcount must be beaten first, and it cannot be claimed remotely.	ANNOUNCEMENT & PROMOTION CMD 1 Spoof source IP to match the target, send from a different port The old port is overwritten. The entry now points nowhere. Goodcount is bypassed entirely.
--	--

Not an eviction primitive	The eviction primitive
---------------------------	------------------------

Falliere 2011 (framing it as a defence: a rogue peer cannot insert two coordinates for one IP, because the old port is replaced by the new one; existing coordinates are only overwritten when goodcount is negative) reconciled with P2PWNEED 2013, Werner co-author (framing the same behaviour as the one weakness found).

CLAIM	TYPE	CONFIDENCE
This primitive exists in the protocol and is documented in the public literature	[F]	HIGH
It defeats goodcount, which is the control that made Sality resilient	[F]	HIGH
Its NAT limitation matches the two-phase shape of the 2026 operation	[A]	MODERATE
It is the primitive CrowdStrike actually used	[A]	LOW A 13-year-old finding mapped onto an undisclosed 2026 technique. Werner's co-authorship is suggestive, not evidential. Alternatives: an unpublished state-machine flaw, an implementation bug in specific builds, or a composite of several primitives

PUBLICATION INSTRUCTION

Label this in any management paper as *implementation detail not publicly disclosed as of 2 September 2026*, and present the hypothesis as a hypothesis. Do not let it harden into fact through repetition — that is exactly how the "unsigned payloads" error at 6.1 propagated.

SECTION 07

The disruption operation

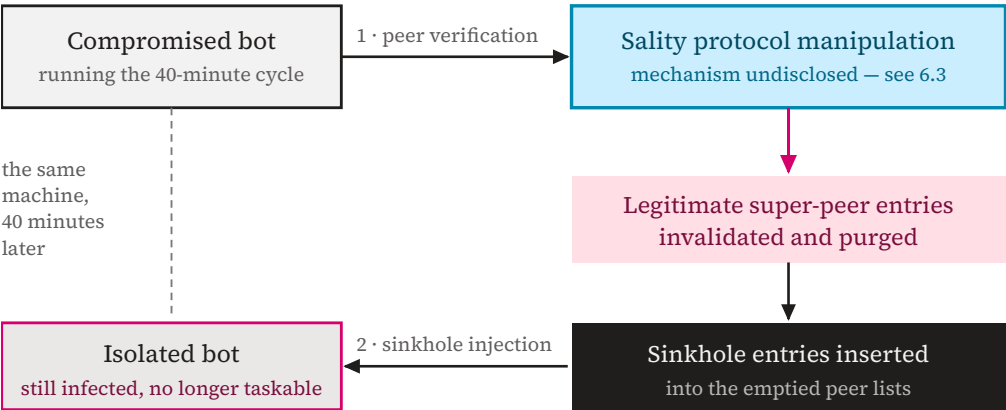
Executed Monday 31 August 2026, announced 1 September. **[F, High — two independent sources.]** Partners: DOJ, FBI, DCIS — the Department of Defense Office of Inspector General's Defense Criminal Investigative Service — the Shadowserver Foundation, with support from Europol and Eurojust and law enforcement in Bulgaria, Hungary and Romania, plus unnamed additional partners.

ROLE	ENTITY OR INDIVIDUAL, PER DOJ [F, High]
US prosecution lead	AUSA Lauren Restrepo , National Security Division, Central District of California
US Attorney's Office	First Assistant US Attorney Bill Essayli , Central District of California
FBI	Patrick Grandy , Assistant Director in Charge, Los Angeles Field Office
DCIS	SAC Kenneth DeChellis , DoD OIG Defense Criminal Investigative Service, Cyber Field Office
Bulgaria	General Directorate Combating Organized Crime
Hungary	National Bureau of Investigation, Cybercrime Department
Romania	Romanian Police / Directorate for Combating Organized Crime / Central Cybercrime Unit
European Union	Eurojust, Europol
US international	DOJ Office of International Affairs

7.1 The operation in one picture

EXHIBIT 15

Two moves, executed inside the malware's own maintenance cycle



Serving two purposes at once: the sinkhole entries give visibility into operation progress and enable infection tracking and victim notification. [F, High]

7.2 Stage one — infiltrate the overlay

WHAT THE BOT CONCLUDED

"The protocol is correct, the endpoint is reachable, therefore this is another peer."

Required full protocol emulation for **both** v3 and v4 — two independent implementations, two key ecosystems, no shared code path. This is the cost that makes the technique hard to replicate, not the primitive.

7.3 Stage two — invert the peer table

EXHIBIT 16

One bot's peer table, before and after

BEFORE

Sality A
Sality B
Sality C
Sality D
Sality E

Operator tasking propagates

AFTER POISONING

Sinkhole 1
Sinkhole 2
Sinkhole 3
Sinkhole 4
...

Operator tasking cannot propagate

CrowdStrike's two steps: remove legitimate peers so bots progressively isolate, then insert sinkhole entries into the emptied lists. Super peers were targeted first as the communication backbone; once isolated, both URL packs and file packs stop propagating. [F, High]

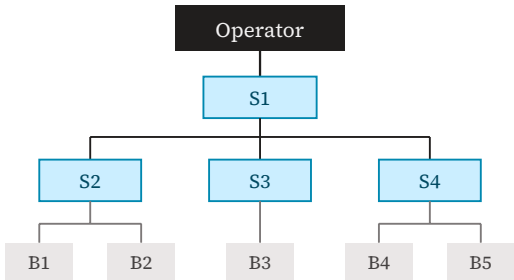
7.4 Why it cascades

Removing the topmost peer achieves nothing — there is no root to cut. What works is manipulating *what the surviving peers believe the topology is*.

EXHIBIT 17

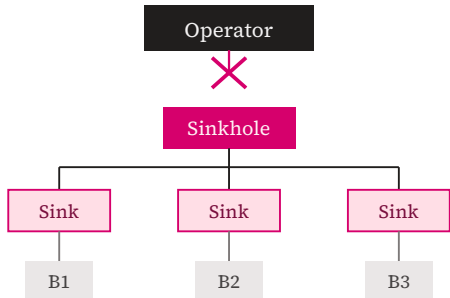
Do not cut the root; rewrite the belief

BEFORE — TASKING FANS OUT



Removing S1 alone achieves nothing: S2-S4 still hold peers.

AFTER — A DEFENDER-OWNED BACKBONE



Every bot's next refresh reinforces the defender's topology rather than the operator's.

Source: CrowdStrike 2026, reconstructed. Structural note: a P2P botnet has no root to cut, which is precisely why it was considered disruption-resistant.

7.5 What the DOJ release adds — and what it conspicuously omits

The DOJ release is the only account of this operation not written by the party that ran it. Reading it against the CrowdStrike post is therefore the most useful single analytic exercise available.

EXHIBIT 18

Corroboration matrix — what two sources agree on, and what rests on one

CLAIM	CROWDSTRIKE	DOJ	NOTE
Executed Monday 31 Aug 2026	Yes	Yes	
A peer-to-peer sinkhole operation	Yes	Yes	Settles sinkholing versus partitioning from a second source
Domain seizures, United States	Yes	Yes	By DOJ, FBI and DCIS
Domain seizures, Europe	Yes	Yes	Bulgaria, Hungary, Romania
Europol and Eurojust participation	Yes	Yes	
Shadowserver victim notification	Yes	Yes	Explicitly via ISPs and CSIRTs
Sality active since 2003	Yes	Yes	
Cryptocurrency theft as the harm	Yes	Yes	
The ~15,000 figure; v3/v4 structure; the peer-list mechanism; EggJagger; the RUB 12.1M / 147M financials; the three DDoS campaigns; the YARA rules and IOCs	Yes	Silent	Not contradicted — simply not independently attested. Confidence unchanged and remains vendor-sourced
Any named suspect, charge, indictment, forfeiture or sanction	Silent	Silent	KJ-13 — conspicuously absent from both

Sources: CrowdStrike, 1 Sep 2026; DOJ/USAO-CDCA release 26-149, 1 Sep 2026. This matrix is the basis on which X-1 is treated as partially discharged.

7.6 The DoD nexus — read carefully

DCIS's participation is unusual enough to warrant explanation, and the release supplies one: SAC DeChellis frames DCIS's involvement around protecting the integrity of the **Department of Defense Information Network** from threats of this kind.

READING	TYPE	CONFIDENCE
DCIS framed its participation in terms of DoDIN protection	[F]	HIGH — direct quotation
DCIS participates because Sality falls within its DoDIN-protection remit	[A]	MODERATE
Sality infections were actually present on DoDIN or defence-contractor systems	[A]	LOW — <i>not stated</i> . The quotation describes a mission priority, not a finding

DO NOT OVER-READ THIS

The temptation is to convert "DCIS was involved" plus "DoDIN is our priority" into "Sality was on defence networks." The release does not say that. It is, however, the most plausible explanation for DCIS's presence and worth one line in a management summary — flagged at Low confidence.

7.7 Policy framing

DOJ situates the operation as advancing the first pillar of the *US Cyber Strategy for America* — "Shape Adversary Behavior" — and describes public-private coordination as central to it. The same framing appeared in the QScan/QTRouter PRC botnet disruption announced a week earlier.

[A, Moderate] that this reflects a sustained US policy posture favouring publicised, private-sector-partnered disruption operations rather than a one-off. Relevant to Section 15: if your organisation ever contemplates participating in such an operation, the current US posture is receptive, and the legal vehicle is a US Attorney's Office working with named foreign cybercrime units.

SECTION 08

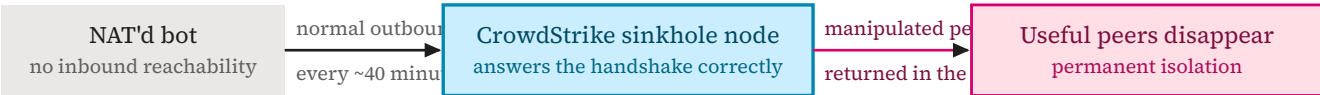
NAT, the seizures, and the residual-tasking race

Most of the population was never reachable from outside. P2PWNEED measured only **36.9% (v3)** and **40.0% (v4)** of enumerated peers as routable, and found that crawling underestimated the true population by factors of 110.6 and 113.3 respectively. CrowdStrike confirms the majority sit behind firewalls or NAT. **[F, High]**

EXHIBIT 19

The passive approach — the hidden majority walks into the trap by itself

The takedown requires access to no victim machine. It travels on legitimate protocol behaviour that the malware performs on its own schedule.



Every 40-minute cycle a hidden bot runs, it walks further into the trap. [A, Moderate-High] — CrowdStrike's characterisation; convergence rate and completeness are not published.

Source: CrowdStrike 2026, reconstructed. P2PWNEED 2013 for the routability measurements.

8.1 Why the domain seizures were not optional

Peer-list poisoning does not erase tasking a bot **already holds**. A bot still carrying a valid signed URL pack will keep fetching from those URLs. CrowdStrike is explicit that the URL takedowns ensure such bots cannot retrieve payloads *during the transition period*.

EXHIBIT 20

Two prongs, one outcome — neither is sufficient alone

PRONG ONE · CROWDSTRIKE Poison the P2P topology No new tasking can reach a bot.	PRONG TWO · LAW ENFORCEMENT Remove the payload URLs Old tasking a bot still holds cannot fetch anything.
Botnet inert	not remediated — see Section 13

Sources: CrowdStrike 2026; DOJ release 26-149. P2PWNEED formalised the second prong as *fallback prevention*, the third mandatory step of any P2P sinkholing operation alongside sinkhole announcement and node isolation.

8.2 The doctrine, and 8.3 seizure scope

P2PWNEED's Sality entry notes that no backup C&C mechanism exists, but warns that as a downloader it could recover through previously dropped malware, and that one must first verify no delivered payload retains download-and-execute capability. The 2026 operation follows that doctrine. **[A, Moderate]** — the correspondence is clear, but CrowdStrike does not cite P2PWNEED.

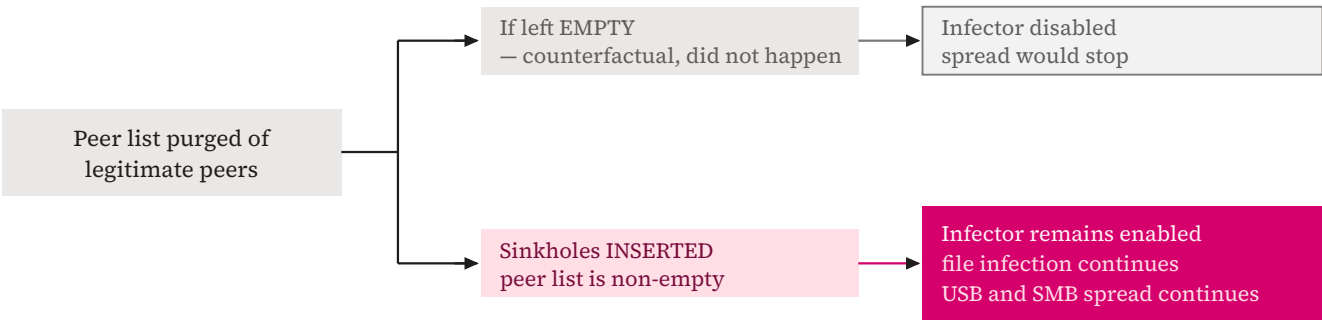
DOJ, FBI and DCIS seized Sality-linked domains in the United States; Bulgaria, Hungary and Romania acted against Sality-linked domains hosted in Europe. Europol and Eurojust participation is confirmed by the primary source. **[F, High]**

8.4 Does propagation continue? A reasoned inference

Falliere established that all infection routines are disabled if the peer list is empty. Had poisoned peer lists ended up *empty*, file infection — and therefore lateral spread via shares and USB — would have stopped as a side effect. They did not.

EXHIBIT 21

The branch that decides whether Sality still spreads



The inference chain: CrowdStrike states sinkhole entries are injected into the emptied peer lists, and that all Sality-infected machines now beacon to CrowdStrike sinkholes. A machine that beacons must hold at least one sinkhole entry. A peer list holding entries is not empty. Therefore the infector is not disabled.

STEP IN THE CHAIN	TYPE	CONFIDENCE
Falliere: infection routines disabled on an empty peer list (2011 code)	[F]	HIGH
That behaviour is unchanged in 2026 builds	[A]	MODERATE — rests on X-2
Post-disruption peer lists contain sinkhole entries	[F]	HIGH
Therefore file infection and lateral spread continue	[A]	MODERATE

DEFENSIVE IMPLICATION

The disruption cuts *tasking*, not *propagation*. Treat any Sality-infected host as still spreading to mapped drives, shares and removable media. **The recommendation is robust to the inference being wrong** — remediate regardless. Note that the infection is now *quieter*: no new payloads means fewer behavioural symptoms to trip on.

SECTION 09

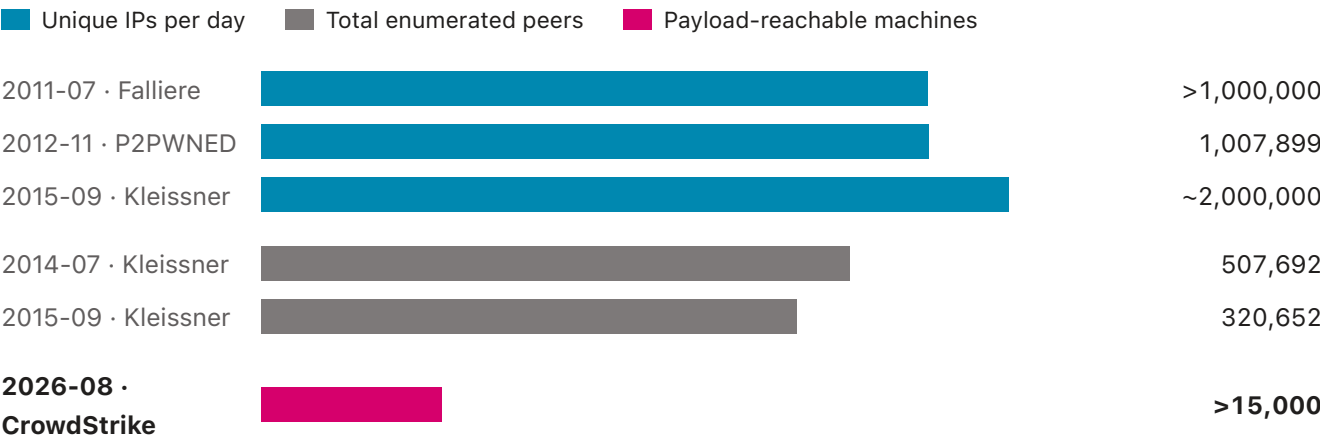
Scale and trajectory

Confirmed: over **15,000** infected machines were reachable for payload delivery. **[F, High]** Everything else about magnitude is a comparison between measurements that were never designed to be compared.

EXHIBIT 22

Measured points only — no interpolation, and three incompatible measures

Bars are logarithmic. They are **not** comparable across measures; the colour tells you which measure each bar belongs to.



Intermediate years 2016–2025: **no data located**. The decline curve is four measured points with a decade-wide hole.

Bar length is proportional to $\log_{10}$ of the value, so visual differences understate the true ratios. Sources as labelled.

DATE	SOURCE	MEASUREMENT	FIGURE
Jan 2011	Falliere	v3 super peers, unique IPs seen by a rogue peer	80,000
Mar–Jul 2011	Falliere	v3 concurrent active super peers	8,000–10,000
Jul 2011	Falliere	v3 unique IPs contacting a rogue server, daily	> 1,000,000
Jul 2011	Falliere	v4 active super peers	~300
Nov 2012	P2PWNEED	v3 / v4 unique IPs at sensor, 24 hours	912,090 / 95,809
Jul 2014	Kleissner	v3 / v4 total peers	415,696 / 91,996
Sep 2015	Kleissner	v3 / v4 total peers	251,459 / 69,193
Sep 2015	Kleissner	All Sality, "up to" unique IPs/day via sinkhole	~2,000,000
Aug 2026	CrowdStrike	Payload-reachable machines	> 15,000

SOURCING CAUTION

Kleissner's deck carries **two** population tables and they are frequently conflated. The 415,696 / 91,996 figures are from 22 July 2014; the September 2015 figures are 251,459 / 69,193. Citing the 2014 table as 2015 understates the 2014–15 decline and overstates the gap to 2026.

DECLINE TO 15,000, BY BASELINE

Falliere Jul-2011, v3 unique IPs/day (1,000,000)	98.50%
P2PWNEED Nov-2012, v3+v4 sensor (1,007,899)	98.51%
Kleissner 2015, "up to" IPs/day (2,000,000)	99.25%
Kleissner Jul-2014, total peers (507,692)	97.05%
Kleissner Sep-2015, total peers (320,652)	95.32%

KJ-6A [A, HIGH]

The decline is very substantial. Every baseline agrees on direction and rough order.

KJ-6B [A, LOW]

The figure depends entirely on which baseline is chosen. Unique IPs/day is inflated by churn and NAT; total peers counts enumerated nodes; payload-reachable is narrower than both. **State the range and the baseline, never a single headline percentage.**

Causal explanation [A, Moderate]: Windows XP end-of-life, universal AV detection of Sality, and the disappearance of the pirated-Windows-without-updates estate that sustained it — Kleissner's reasoning, still plausible but

untested against 2016–2025 data.

FRAMING FOR MANAGEMENT

The technical achievement is genuine and the *technique* is the story. This closed a long decline; it did not decapitate an active giant. CrowdStrike itself frames the significance as architectural — that P2P, long considered a shield against disruption, is not invincible.

SECTION 10

Precedent — the technique lineage

CrowdStrike places Sality in the same class of technique as its 2014 GameOver Zeus and 2017 Kelihos disruptions, adapted to Sality's protocol. **[F, High]** The research thread underneath is one researcher's fifteen-year arc — which is a caution as much as a credential.

EXHIBIT 23

Three operations, one abstraction — and the literature that produced it

OPERATIONAL LINEAGE



RESEARCH THREAD

- 2011 Falliere (Symantec) publishes the full protocol reverse-engineering, including both RSA public keys with an invitation to factorise them. Names the v3 DNS-takeover path; notes a "cluster of rogue super peers" as a possible route against v4.
- 2013 P2PWNEED — Rossow, Andriesse, **Werner**, Stone-Gross, Plohmann, Dietrich, Bos. Models resilience formally. Finds the announcement port-overwrite eviction primitive. Rates Sality *extremely resilient*.
- 2013 Werner takes down Kelihos live on stage at RSA.
- 2014 Werner and CrowdStrike contribute to the GameOver Zeus disruption.
- 2017 Kelihos / ZOMBIE SPIDER takedown.
- 2026 Werner runs the Sality disruption live on stage at Day Zero — *"the most complex botnet takeover we have ever done."* The YARA rules ship with the same key bytes Falliere published in 2011.

[F, High] for the sequence; [A, Moderate] for reading it as a single deliberate arc. **Independence caution:** Tillmann Werner authors or co-authors P2PWNEED, the 2026 CrowdStrike post and the public Sality dissector. The apparent convergence between the 2013 research and the 2026 operation is substantially the same researcher agreeing with himself — see 17.6.

SECTION 11

Actor profile — SALTY SPIDER

11.1 Attribution

The attribution rests on a chain of toponyms in twenty-one-year-old strings. It is strong on the Russia nexus and progressively weaker as it narrows.

EXHIBIT 24

From string evidence to a place name — four links, each weaker than the last

STRING EVIDENCE, 2003–2005 SAMPLES

"Message from ST v2.93 – Sector(c),
Salavat-city 2004"
"TROJ SECTOR v2.93 BETA"
"Copyright (c) by Sector"
"Thanx to iMAGER, Alien-Z"
"Simple Poly Engine v1.1a (c) Sector"

Exfiltration: 11581@MAIL.RU → LAMERC00L@RAMBLER.RU,
IMAGER@MAIL.RU, ALIEN-Z@MAIL.RU

THE CHAIN

- Sality derived from **Salavat city**
- Kuku Russian for hide-and-seek
- Sector the author's handle



Salavat is a city in the **Republic of Bashkortostan**, Russia



CrowdStrike: SALTY SPIDER *"likely operating out of the Republic of Bashkortostan, a region close to the Kazakhstan border"*

Corroborating behavioural indicators from the 2026 post: proceeds denominated in rubles with purchasing power assessed in that economy; the Feb 2022 attack assessed as patriotically motivated; the Sep 2023 target a Russian exchange the operator likely used to cash out; and consistent reference to a single criminal actor.

CLAIM	TYPE	CONFIDENCE
The 2003–05 author used the handle "Sector" and was associated with Salavat	[F]	HIGH — direct string evidence, independently reported by Symantec, CrowdStrike and LookingGlass
The operation has a Russia nexus	[A]	HIGH — language, targeting, cash-out channel, ruble economics and vendor attribution all converge
Specifically Bashkortostan	[A]	MODERATE — rests on the Salavat toponym in 2003–05 strings; CrowdStrike hedges with "likely"
The 2026 operator is the same individual as the 2003 author	[A]	LOW — asserted by no source. String evidence is 21 years old; three handles appear in early material; Falliere referred to "the authors" and "the same gang"
A single operator rather than a group	[A]	LOW-MODERATE — CrowdStrike's characterisation, unexplained; contradicted in tone by Falliere's plural

The operator remains publicly unidentified. No arrests, no indictment, no forfeiture, no sanctions — technical disruption only. **[F, High]** — the DOJ release announces seizures and disruption only.]

11.1a Vendor attribution is not government attribution

This distinction matters enough to state separately, because it is easy to collapse and hard to un-say once published.

EXHIBIT 25

Same day, same operation, two very different postures

	CROWDSTRIKE · 1 SEP 2026	DOJ / USAO-CDCA · 1 SEP 2026
Actor named	SALTY SPIDER	None
Nationality	Russian	Not stated
Location	Bashkortostan (2019 post)	Not stated
Operator characterisation	"a single criminal actor"	None
Motivation	Assessed across three DDoS cases	Not stated

The US government made no public attribution.

Reuters reported that the Justice Department said Sality was based out of Russia, without further detail. That statement does **not** appear in the CDCA press release; it presumably came from a separate FBI or DOJ national statement or a press briefing. Locate that source before repeating it.

DRAFTING INSTRUCTION

Write "CrowdStrike assesses the operator to be Russian" — never "Sality is Russian-attributed" unqualified, and never "the US government attributes Sality to Russia." The absence of a charging document means there is no attribution that has been tested against an evidentiary standard.

11.2 Aliases

TYPE	VALUES
Actor	SALTY SPIDER (CrowdStrike)
Author handles	Sector, iMAGER, Alien-Z
Malware family	Sality, KuKu, SalLoad, Kookoo, SaliCode, Kukacka, Win32.HLLP.Kuku
AV detections	W32.Sality.AE, Virus.Win32.Sality, Virus:Win32/Sality
Primary payload	EggJagger (clipjacker)
Related tooling	Win32/Pramro — SOCKS proxy trojan, shares code with Sality

11.3 Monetisation

EXHIBIT 26

Three business models in twenty-three years, and one abrupt pivot

2003–2008	2008–2017	2017–2026
Info-stealer	Pay-per-install	Cryptocurrency
Basic file infector with email exfiltration.	Spam relay, SOCKS proxies, credential theft, website infection via stolen FTP credentials, distributed VoIP/SIP cracking, DDoS.	EggJagger clipjacking. Proxy and spambot payloads dropped entirely in 2017 — an abrupt, complete pivot.

METRIC	VALUE	CONFIDENCE
Actual damages, EggJagger only	~RUB 12.1M (~US\$150,000)	[F] MODERATE — CrowdStrike estimate, method not published
Peak never-spent portfolio value	~RUB 147M, January 2025	[F] MODERATE
Nominal USD at peak	~US\$1.35M	[F] MODERATE
CrowdStrike's purchasing-power framing	≈ US\$4M in a Western capital	[A] LOW — a rhetorical comparison, not a measurement

Do not combine these figures into a single conversion. RUB 12.1M ≈ US\$150,000 implies ~81 RUB/USD; RUB 147M ≈ US\$1.35M implies ~109 RUB/USD. The figures are from different periods — cumulative realised versus January 2025 peak — so the implied rates differ. Quote them separately with their periods attached.

The estimate covers **EggJagger only**; other payload families provided additional revenue. Around US\$150k realised over eight years is modest for the world's most resilient P2P botnet — consistent with an operator extracting rather than reinvesting, which is one plausible contributor to the population decline **[A, Low–Moderate]**.

11.4 Victimology

Fundamentally **non-targeted**. CrowdStrike observed no consistent nation or sector selection, with two unexplained anomalies: higher v3 volumes in Romania, higher v4 volumes in Venezuela. **[F, Moderate]** — from the 2019 profile, not restated in 2026.

SOURCE	TOP AFFECTED	CONFIDENCE
Falliere 2011 (v3 super peers)	Romania, India, Brazil	[F] High for 2011
Kleissner 2015 (% per day)	India 19.7, Egypt 9.0, Vietnam 8.7 , Pakistan 6.3, Iran 5.5, Indonesia 4.7 , China 4.0, Thailand 3.3 , Turkey 2.6, Philippines 2.6 , Brazil 2.5, Russia 2.3	[F] High for 2015

REGIONAL RELEVANCE [A, LOW-MODERATE]

Four of the top eleven in 2015 were ASEAN. But this distribution is **eleven years old**, and the population has since fallen by roughly two orders of magnitude — there is no reason to assume the geographic mix survived the decline unchanged. CrowdStrike's post contains an infection-geography map whose per-country breakdown is not in the text. **Obtain that before making any regional exposure claim.**

- **LookingGlass (2022):** Sality in 13% of financial services and 11.87% of energy organisations in its dataset. **[F, Low-Moderate]** — vendor marketing material, methodology and denominator unpublished.
- **Dragos MIMICS:** Sality among the most common malware families in ICS environments, 1,225 detections. **[F, Moderate]** — MIMICS dates to the 2017 SANS ICS Summit. Treat as historical.
- **Dragos PLC-cracker campaign (2022, assessed ongoing):** Sality distributed inside fake PLC/HMI password-cracking tools advertised on social media — ABB, Allen Bradley, Automation Direct, Fuji Electric, LG, Mitsubishi, Omron, Panasonic, Pro-Face, Siemens, Vigor, Weintek. The Automation Direct tool genuinely retrieved passwords by exploiting **CVE-2022-2003** while dropping Sality. **[F, High]** — primary vendor research with a CVE and a vendor firmware fix.

The PLC-cracker campaign is the **highest-concern delivery vector**: it targets engineers with engineering-workstation access and a strong operational incentive to run an untrusted binary. It is independent of the botnet and continues regardless of the takedown **[A, Moderate]** — no source states it has stopped.

11.5 Behavioural traits

CrowdStrike's assessment is that although operations were primarily financially motivated, three campaigns show willingness to weaponise the botnet for personal or political ends at short notice.

DATE	TARGET	ASSESSED MOTIVATION	CONFIDENCE
Apr 2016	forex2030[.]com — Arabic-language natural-resource trading site, rendered unresponsive	Unclear; possibly extortion or suppressing unfavourable information	Occurrence [F] Moderate; motivation [A] Low — CrowdStrike states it remains unclear
25 Feb 2022	kharkovforum[.]com — Ukrainian forum with a live thread on the Kharkiv offensive. HTTP flood	Patriotic; suppression of invasion discussion	Occurrence [F] Moderate; motivation [A] Low–Moderate — CrowdStrike's wording is "likely aligned"
Sep 2023	AvanChange, a Russian cryptocurrency exchange	Impulsive personal grievance; payload compiled seconds before upload	Occurrence [F] Moderate; motivation [A] Low — inferred from compile timing alone

Independently sourced retaliation against researchers

Kleissner 2015; not mentioned by CrowdStrike. In each case the sole TCP-source attacker was a known Sality infection and the target was the Virus Tracker sinkhole.

#	DATE	VOLUME	VECTORS
1	27 Nov 2014	1 Gbps	ICMP + UDP + TCP
2	30 Jan 2015	10 Gbps	UDP + TCP + NTP amplification
3	13 Mar 2015	120 Gbps	NTP + DNS amplification
4	21 Jun 2015	10 Gbps	UDP

EXHIBIT 27

Four behavioural inputs, one conclusion about residual risk

Financially motivated — the 23-year baseline	[A, High]
+	
Patriotic alignment — Kharkiv, 24 hours after the invasion	[A, Low–Moderate]
+	
Impulsive retaliation — AvanChange compile timing	[A, Low]
+	
Anti-researcher DDoS — four attacks on a sinkhole operation	[F, Moderate]
=	
An operator who has previously attacked exactly the kind of infrastructure CrowdStrike has now stood up.	[A, Moderate]

P2PWNEE specifically warns that sinkholes are conspicuous and invite counter-attack, whereas partitioning attacks do not expose that surface. CrowdStrike chose sinkholing for the victim-notification benefit. That is a considered trade, and the residual risk sits with the sinkhole infrastructure. [A, Moderate]

Other traits

- **Disciplined key management [A, High]** — 23 years, no key compromise after v2. Now evidenced at 12.1, though see KJ-9b: discipline and inability are hard to separate.
- **Iterative engineering against defenders [A, High]** — v4 exists specifically to close the unsigned-executable hole in v3.
- **Low profile as strategy [A, Moderate]** — no ransomware, no extortion, no leak site, no brand. Whether deliberate strategy or simply a small operation is not evidenced.
- **Persistent OPSEC failures [F, High]** — the Sector(c), Salavat-city strings; Network 4 URL packs containing entries that could never resolve — a non-existent .ds TLD, the bare string slwocfd — left uncorrected for years.

SECTION 12

Protocol ossification

Confirmed by the primary source **[F, High]**: Sality's P2P protocol cannot be patched. Because it spreads by attaching to executables on disk, releasing an updated variant would mean competing with the existing strain for the same host files — fragmenting the botnet rather than upgrading it. The protocol behaviour bots exhibit today is what they exhibited twenty years ago.

EXHIBIT 28

Resilience bought longevity at the cost of adaptability

STEP ONE	STEP TWO	STEP THREE	STEP FOUR
A protocol defect ships in 2009 and 2010	The installed population cannot be cleanly patched	The weakness becomes permanent	A defender eventually reverse-engineers it — catastrophic, systemic, unrecoverable

Source: CrowdStrike 2026, with the same reasoning applied by Falliere to the v2→v3 transition in 2011. The provable form of this chain is the key comparison below.

12.1 The RSA keys — independently verified

CrowdStrike's 2026 YARA rules detect live Sality by scanning process memory for the botnet's hardcoded RSA public keys, alongside the string IPFILTERDRIVER. Falliere published those same moduli in Annex B of the July 2011 paper, inviting readers to factorise them. Both were normalised — whitespace stripped, case-folded — and compared byte for byte.

EXHIBIT 29

Fifteen years apart, byte for byte identical

SALITY V3 MODULUS	RSA-1024, E = 65537	SALITY V4 MODULUS	RSA-2048, E = 65537
CrowdStrike YARA, 2026-08-18	128 bytes	CrowdStrike YARA, 2026-08-18	256 bytes
Falliere Annex B, July 2011	128 bytes	Falliere Annex B, July 2011	256 bytes
RESULT: IDENTICAL		RESULT: IDENTICAL	
begins 99 65 40 34 cd ae 9d b3 ...		begins bb d2 96 8e ed 0b 93 8a ...	
ends ... 26 1a 32 9b		ends ... 18 e0 d0 7b 3b	

Comparison computed and verified during preparation of this document. Independently verifiable by anyone holding both documents. [F, High]

KJ-9A [F, HIGH]

The keys are byte-identical across fifteen years.

KJ-9B [A, MODERATE-HIGH]

This shows the operator *could not* rotate. A new embedded public key means a new protocol version, which means a separate network, abandoning the installed population. The alternative — that he simply chose not to — cannot be excluded, though it is hard to reconcile with an operator who twice rebuilt his network to close weaknesses.

- 1 **Anyone could have written these detection rules in 2011.** The key material has been public for fifteen years. [F, High]
- 2 The operator's most sensitive cryptographic asset was frozen and published. [F, High]
- 3 This is the provable form of KJ-5. Where CrowdStrike asserts the protocol could not be patched, the key comparison evidences it. [A, High]

THE INVERSION WORTH PUTTING IN THE ASSESSMENT

The same architecture that made Sality immune to centralised takedown also froze its protocol and its cryptography. A botnet that can push signed code updates to itself does not have this problem — which is precisely the property to test for in any candidate target.

SECTION 13

Disruption is not remediation

What was achieved is a **network quarantine at botnet scale**. Every infected executable on every victim disk is still infected and still active. Shadowserver supports ISPs and CSIRTs with infection identification and victim notification. **[F, High]**

EXHIBIT 30

What changed, and what did not

CHANGED	UNCHANGED
The bot cannot receive useful C2	The infected executable still exists and still runs
New URL packs and file packs cannot reach it	Malware already installed remains active
Payload delivery has stopped	File infection and lateral spread continue (8.4)
Verified victim telemetry now exists	Safe Mode may still be unavailable

Sinkholing, not partitioning [F, High — two independent sources]. CrowdStrike states the sinkhole entries provide visibility into operation progress and enable infection tracking and victim notification; DOJ independently describes the action as a peer-to-peer sinkhole operation.

Notification pathway, now independently confirmed [F, High]: DOJ states that Shadowserver is working with internet service providers and Computer Security Incident Response Teams to identify infections and aid victim notification and remediation. Shadowserver's CSIRT distribution is global and includes national CERTs.

CLAIM	TYPE	CONFIDENCE
A victim-notification mechanism exists and runs through ISPs and CSIRTs	[F]	HIGH — corroborated by DOJ, independent of the vendor
That pathway is capable of reaching national CERTs outside the US and EU	[A]	MODERATE — Shadowserver's ordinary distribution model, not stated for this operation specifically
Singapore or regional constituents will in fact receive Sality notifications	[A]	LOW — unevidenced. Action: confirm directly with SingCERT or your national CSIRT contact rather than assuming

SECTION 14

Detection, hunting and remediation

14.1 Confirmed post-disruption indicators

EXHIBIT 31

The single highest-value indicator, and the final tasking the botnet ever carried

LIGHTHOUSE SINKHOLE IP [F, HIGH]

188.166.101[.]148

Review network logs and endpoint telemetry for **UDP traffic** to this address. Any match indicates a Sality infection requiring remediation.

SALITY V3 — URL PACK VERSION 25202

```
http[:]//theunforgiven.p8[.]hu/img/top.gif
http[:]//paineIwebradiodigital.awardspace[.]info/v
3/readme.pdf
http[:]//sgwebdesigner.free[.]fr/left.gif
http[:]//www.yonelco[.]com/icon.png
http[:]//pozdravizbeograda[.]com/readme.pdf
http[:]//highclass.atspace[.]com/styles.gif
http[:]//situluimihai.3x[.]ro/top.png
```

SALITY V4 — VERSION 31010

```
http[:]//gatheredovertime[.]com/n
b4
http[:]//imagebucket[.]biz/nv4
```

Source: CrowdStrike 2026. [F, High] Add all nine URLs to proxy and DNS blocklists, and hunt historically.

FREE-HOSTING PATTERN [A, MODERATE]

p8.hu, awardspace.info, free.fr, atspace.com and 3x.ro are free web hosts — a shift from the compromised-legitimate-site pattern of 2011–15, consistent with a low-overhead operation. Nine URLs is a small sample; do not over-read.

MASQUERADE EVOLUTION [F, HIGH]

The historic /logo.gif and /bottom.gif convention has broadened to readme.pdf, icon.png, styles.gif, and in v4 to extensionless paths. **Detection logic keyed to /logo.gif would have missed the final packs.**

SEQUENCE-ID ANOMALY

v3 reached 25202 and v4 31010, against 241 and 96 in 2015 telemetry. Either the numbering scheme changed or pack cadence increased by roughly two orders of magnitude. v4 — always the far smaller network — carries the *higher* number. **Unexplained.** [F, High] for the observation; [A, Low] for any explanation.

14.2 YARA — memory scanning

CrowdStrike published CrowdStrike_Salityv3_01 and CrowdStrike_Salityv4_01, both dated 2026-08-18. The structure of each is two

conditions:

```
strings:
  $ = "IPFILTERDRIVER"           // the amsint32 packet-filter component
  $ = { <RSA public modulus bytes> } // v3: 128 bytes / v4: 256 bytes
condition:
  all of them
```

They scan **running processes**, not files on disk — the correct choice, since the polymorphic infector produces a different decryptor per infected binary but the same in-memory payload. **[A, Moderate]** for that rationale; CrowdStrike does not state it. Take the rules from the CrowdStrike post directly; the modulus bytes are independently recoverable from Annex B of the 2011 Symantec paper if you need to modify or extend them.

14.3 Host indicators

INDICATOR	TYPE	CONFIDENCE	NOTES
Mutex uxJLpe1m	Mutex	[F] High	Unique across variants. Best host IOC and inoculation vector
Mutexes purity_control_4428, kukuttrusted!	Mutex	[F] Moderate	Kleissner 2015, variant-specific
Mutexes <ProcessName>M_<PID>_	Mutex	[F] High	Many instances is a strong indicator
Service amsint32	Service	[F] High	Stable across variants; driver filename usually pseudo-random
\Device\amsint32, \DosDevices\amsint32	Device	[F] Moderate	Kleissner / BU-CERT, not in Falliere
String IPFILTERDRIVER in process memory	Memory	[F] High	Confirmed present in 2026 samples via the YARA rules
SafeBoot keys deleted, HKCU and HKLM	Registry	[F] High	Blocks Safe Mode recovery
Peer list under a username- seeded pseudo-random HKCU key	Registry	[F] High	Rows of REG_DWORD named A1_0, A1_1, A2_0 ...
Security Center overrides set	Registry	[F] High	AntiVirusOverride, AntiVirusDisableNotify, FirewallDisableNotify, FirewallOverride, UpdatesDisableNotify, UacDisableNotify, AntiSpywareOverride
autorun.inf plus a random .exe/.cmd/.pif at a drive root	File	[F] High	Infected Calculator or Minesweeper copy — the USB vector
Entry points overwritten with CC C3 CC C3 ...	File	[F] High	Destroyed security binaries
Missing or deleted .vdb, .avc files	File	[F] High	AV definition files hunted and deleted
AV updates failing; AV vendor sites unreachable	Behaviour	[F] High	Driver-level packet filtering

14.4 Network detection

EXHIBIT 32

Rule logic — high-confidence identification with no secret material

UDP, PORTS ~4,224–17,083 PLUS 9,674

- 1 Take the first two bytes as WORD *h*, the next two as WORD *n*
- 2 Check $n == \text{packet_len} - 4$ — a cheap structural filter
- 3 Derive the RC4 key $k = \text{MAKE_DWORD}(h, n)$
- 4 RC4-decrypt the remainder
- 5 Verify decrypted[0x00] (Version) is in {3, 4} and decrypted[0x05] (Command) is in {1, 2, 3}

High-confidence Sality identification — no secret material required.

Derivation note. A range of "roughly 3,200–18,100" is sometimes quoted; it comes from applying the formula across the full printable-ASCII space. Windows computer names are restricted to letters, digits and hyphen, giving 4,224–17,083 (uppercase-only: 4,224–10,299) across 1,751 distinct values. 9,674 is also reachable via the formula, so it does not reliably identify the short-name fallback case. The constants *C* and *f* are implementation-specific — **widen the range rather than narrow it.**

- **UDP to 188.166.101.148** — confirmed infection, highest priority.
- Periodic outbound UDP fan-out to many diverse public IPs on a **fixed source port** at a **~40-minute cadence** from a workstation.
- v4 only: TCP on (UDP port + 19). Kleissner records a default of 9673, which conflicts — detect on both.
- HTTP GETs to the final URL-pack paths, and more generally small image- or PDF-named files returning RC4-encrypted PE content from free-hosted sites.

14.5 Remediation

- **Existing malware remains active.** Isolation is not cleanup. **[F, High]**
- **Propagation has likely not stopped.** Treat any infected host as still spreading. **[A, Moderate]**
- **Inoculation:** pre-creating uxJLpe1m prevents infection — a cheap compensating control where EDR cannot run. **[A, Moderate]** against 2026 variants. Test first.
- **Cleaning is destructive by nature.** Sality is a virus, not a trojan; it modifies legitimate binaries in place.
- **Safe Mode may be unavailable** — the protector deletes the SafeBoot keys. Restore them first.
- Assume any USB or shared drive touched by an infected host is contaminated.

SECTION 15

Applicability assessment

15.1 The generalisable insight

The reusable idea is **not** "poison a peer list." It is: *attack the unauthenticated control-plane information of a decentralised malware overlay rather than its authenticated command payloads*. By controlling **who bots believe they should talk to**, the defender never needs the operator's signing key.

EXHIBIT 33

Two planes, one of which is worth attacking

DATA PLANE / TASKING	CONTROL PLANE / TOPOLOGY
Signed and difficult to forge RSA-signed URL packs. Sequence-ID monotonicity. In v4, signed executables as well. Do not attack this	Unauthenticated throughout Peer identity · peer discovery · neighbour maintenance · peer eviction Attack here

Technical applicability: HIGH as a technique family [A, Moderate]. Target-specific applicability: CONDITIONAL [A, High] — it depends entirely on the target's peer-admission design.

15.2 Candidate-scoring dimensions

EXHIBIT 34

Thirteen questions to ask of any candidate — Sality answered every one the wrong way

QUESTION	SALITY	TAKEDOWN IMPLICATION
Can an arbitrary node join?	Yes	Critical weakness
Is peer identity cryptographically authenticated?	No	Critical weakness
Can peers advertise and discover other peers?	Yes	Enables poisoning propagation
Is peer state mutable?	Yes	Required
Is the neighbour list bounded?	Yes — 1,000	Makes displacement feasible
Can remote behaviour cause peer eviction?	Yes	Critical
Are publicly reachable backbone nodes identifiable?	Yes	Provides initial targets
Do NAT'd bots rely upon those nodes?	Yes	Allows poisoning to cascade
Are commands dependent upon the P2P overlay?	Yes	Isolation kills C2
Is there independent fallback C2?	No	Decisive
Can the operator remotely repair the P2P code?	No — the file-infector architecture forbids it	Makes disruption durable
Can the operator rotate cryptographic keys?	No — a new key is a new network	Makes detection durable
Are residual payload servers removable?	Yes , via LE coordination	Completes disruption

A BOTNET IS A STRONG CANDIDATE WHEN ALL FIVE HOLD

Unauthenticated peer admission

Remotely influenceable neighbour table

Finite or replaceable peer state

P2P essential for tasking

No robust independent recovery channel

Derived from P2PWNET's resilience model and the mechanics in Sections 5 and 6 of this document.

15.3 Where this approach will not work

EXHIBIT 35

Five blockers — and modern threats are built the way Sality was not

Authenticated peers

If neighbour advertisements are signed or identities bound cryptographically, you cannot inject your own nodes.

```
peer record: IP + port + nodeID + signature
```

Strong Sybil resistance

Reputation, proof-of-work, long-lived authenticated identities or constrained admission make mass introduction of defender nodes impractical.

Independent fallback C2 — the decisive factor

Break P2P and the DGA and Tor channels still work. Poisoning P2P accomplishes little. GameOver Zeus is the canonical example of why simultaneous coordinated disruption matters.

P2P	DGA	Tor
broken	works	works

Independently signed repair channel

If the operator can push a new protocol, new bootstrap nodes, a new public key or a peer-table reset through a separate mechanism, they recover. This is precisely what Sality could **not** do.

Public P2P substrate

Malware using something like the BitTorrent DHT as an external dead-drop is a different problem: the defender does not control the P2P implementation and cannot rewrite the legitimate global network's topology. CrowdStrike's own Glassworm takedown (May 2026) faced exactly this — blockchain, P2P and legitimate web services as parallel resolution layers, requiring all four channels struck simultaneously. **Glassworm is the useful contrast case for your framework. [A, High]**

Sources: P2PWNEED 2013; CrowdStrike GameOver Zeus, Kelihos and Glassworm write-ups.

15.4 Investigation sequence for a candidate botnet

- 01 **Reverse-engineer peer admission** — can an unauthorised participant complete peer establishment?
- 02 **Map neighbour-table semantics** — size limits, eviction, aging, reputation, replacement, bootstrap behaviour.
- 03 **Determine who controls peer advertisements** — peer-generated or operator-signed.
- 04 **Identify topology** — ordinary peers versus routable relays and super peers; graph centrality.
- 05 **Test propagation** — can controlled membership information travel beyond the directly contacted peer?

- 06 **Identify recovery mechanisms** — DGA, DNS, Tor, blockchain, public services, hardcoded peers, secondary protocols.
 - 07 **Identify update mechanisms** — can the operator repair or reset topology remotely? Can they rotate keys?
 - 08 **Identify residual tasking** — cached URLs, configs, files usable after P2P isolation.
 - 09 **Model sinkhole scale** — how much controlled infrastructure, and how fast does peer state converge?
 - 10 **Only then** assess operational feasibility with appropriate legal and law-enforcement authorisation.
-

POINT 10 IS NOT A FORMALITY

CrowdStrike's technical work sat inside a coordinated multinational law-enforcement operation with DOJ, FBI, DCIS, Europol, Eurojust and three European national authorities. Actively manipulating third-party infected systems and seizing infrastructure is not something an organisation should replicate against a live botnet merely because the protocol permits it. P2PWED's authors devoted a section to the ethics of unsolicited communication with infected hosts, and Symantec in 2012 called a public Sality removal plan "*a definite no*" on exactly these grounds.

15.5 Defensive applicability

ASPECT	APPLICABILITY	CONFIDENCE	ACTION
Sinkhole telemetry	High	[F] High	Alert on UDP to 188.166.101.148. Any hit is a confirmed infection
YARA memory scanning	High	[F] High	Deploy both published rules against running processes
Final URL pack IOCs	High	[F] High	Add the nine URLs to proxy and DNS blocklists; hunt historically
Continued propagation	High	[A] Moderate	Remediation urgency unchanged; symptoms now quieter
File-infector risk	High	[A] High	EDR behavioural detection, file-integrity monitoring, control of SMB shares and removable media
OT and legacy estate	High	[A] Moderate	uxJLpe1m inoculation and USB/autorun controls where EDR cannot run
PLC/HMI cracker campaign	High	[A] Moderate	Engineer awareness and policy. Independent of the botnet
Regional exposure sizing	Deferred	[A] Low	2015 geography is too old to act on. Obtain CrowdStrike's per-country breakdown first
Network traffic profiling	Medium	[A] Moderate	Use the 14.4 decryption logic; widen the port range
Replicating the takedown	Low / N/A	[A] High	Needs protocol RE, sinkhole infrastructure and law-enforcement authority

SECTION 16

Residual gaps

#	GAP	STATUS
1	The exact eviction primitive	Deliberately withheld. The 6.3 hypothesis is [A, Low]
2	Current v3 / v4 split of the 15,000	Not broken out
3	URL pack sequence-ID jump (241→25202, 96→31010)	Unexplained; v4 higher than v3 despite being smaller
4	Whether the 2026 operator is the 2003 author	[A, Low]. Not asserted by any source
5	CrowdStrike's infection-geography figure	Image only; per-country breakdown not in the text. Blocks any regional exposure claim. DOJ gives no geography either
6	Population data 2016–2025	None located. The decline curve is four measured points with a decade-wide hole
7	Whether victim notification reaches ASEAN constituencies	Pathway (ISPs plus CSIRTs) independently confirmed by DOJ. Regional delivery unevidenced — confirm with SingCERT
8	Independent verification of the disruption's completeness and effect	DOJ corroborates that the operation happened and its shape, but states no infection count, no mechanism and no effectiveness claim. X-1 is discharged only in part
9	The separate DOJ/FBI statement reported by Reuters as attributing Sality to Russia	Not present in the CDCA release. Locate before repeating any government attribution
10	Whether Sality was present on DoDIN or defence-contractor systems	DCIS participation is framed around DoDIN protection, but no infection is stated
11	Any charging document, complaint or seizure warrant	None released. Without one, no attribution has been tested against an evidentiary standard

Known contradictions in the corpus

- **Payload signing.** Kleissner (2015) says payloads carry no signature; Falliere (2011) says v4 signs and verifies. Resolution: the claim is v3-scoped (6.1).
- **v4 TCP port.** Falliere: UDP + 19. Kleissner: default 9673. Prefer Falliere; detect on both.
- **Announcement port overwrite.** Falliere frames it as a defence; P2PWNEED frames identical behaviour as an attack primitive. Not a contradiction — a difference in adversarial reading (6.3).
- **Operator singular versus plural.** CrowdStrike (2026): a single criminal actor. Falliere (2011): "the authors," "the same gang." Unresolved (11.1).
- **Simplified mechanism descriptions.** Accounts describing crafted responses that cause bots to purge legitimate super peers are a simplification. Falliere shows the *server* thread never modifies goodcounts, only the *client* thread does — so spoofing malformed packets from known-good peers to tank reputation does **not** work.

SECTION 17

Source list

17.1 Primary sources — the disruption

REF	SOURCE	VALUE	INDEPENDENCE
E	CrowdStrike Counter Adversary Operations, <i>Peer Pressure: Inside the Sality Botnet Disruption Operation</i> , 1 Sep 2026	Primary. Operation mechanics, partners, EggJagger economics, three DDoS campaigns, IOCs, YARA rules, lighthouse IP	Vendor self-report on its own operation. See X-1
F	DOJ / U.S. Attorney's Office, Central District of California, <i>Sality Malware Disrupted in International Cyber Takedown</i> , release 26-149, 1 Sep 2026	Primary. Law-enforcement scope, named agencies and officials, Shadowserver notification pathway, policy framing. Makes no attribution claim	The only account not authored by the party that ran the operation. Partially discharges X-1

17.2 Primary sources — protocol and actor

REF	SOURCE	VALUE	INDEPENDENCE
A	Falliere, N. <i>Sality: Story of a Peer-to-Peer Viral Network</i> , Symantec Security Response, v1.0, July 2011	Primary technical. Full protocol reverse-engineering, packet format, client-thread flowcharts (Figures 4, 6, 10, 11), RSA public keys (Annex B), AV target and packet-filter lists (Annex A)	Independent of E; predates it by 15 years
B	Rossow, Andriesse, Werner , Stone-Gross, Plohmann, Dietrich, Bos. <i>SoK: P2PWNEED — Modeling and Evaluating the Resilience of Peer-to-Peer Botnets</i> , IEEE S&P 2013	Formal resilience model; the announcement port-overwrite eviction primitive; crawling versus sensor population methodology; takedown ethics	Peer-reviewed. Shares an author with E and I — not fully independent
C	Kleissner, P. <i>Sality 2003 — Today</i> , Botconf 2015, Paris	Author attribution strings; network 3/4 population tables (Jul 2014, Sep 2015); URL pack corpus; payload RC4 key; anti-researcher DDoS record	Independent of E. Conference deck, not peer-reviewed
D	CrowdStrike, <i>Who is SALTY SPIDER (Sality)?</i> , 6 Sep 2019	Bashkortostan attribution, aliases, 2017 cryptocurrency pivot, EternalBlue, v3/v4 regional skew	Same vendor as E
D2	CrowdStrike, <i>SALTY SPIDER</i> adversary profile	Standing actor profile	Same vendor as E
L	Malpedia (Fraunhofer FKIE), <i>win.sality</i> and <i>SALTY SPIDER</i>	Family and actor reference, cross-vendor naming	Independent aggregator

17.3 Technical corroboration

REF	SOURCE	VALUE	INDEPENDENCE
I	Werner, T. <i>sality-dissector — Wireshark/Lua dissector</i>	Confirms the three message types on the wire; directly usable for detection engineering	Same author as B and E
K	F-Secure, <i>Virus:W32/Sality.Q</i>	EPO byte counts — variant-specific to Sality.Q, do not generalise	Independent
M	Bournemouth University CERT, <i>Sality rootkit analysis</i>	amsint32 driver, device names, size and targeting	Independent
N	Kaspersky Threats, <i>Virus.Win32.Sality</i>	First detection July 2003; polymorphic decryptor and modular payload structure	Independent

17.4 Victimology and sector exposure

REF	SOURCE	VALUE	INDEPENDENCE
H	Dragos, <i>The Trojan Horse Malware & Password "Cracking" Ecosystem Targeting Industrial Operators</i>	PLC/HMI cracker delivery vector, CVE-2022-2003, AV-update-blocking and its CIP-007-6 consequence	Independent vendor research with a CVE and a vendor firmware fix
H2	BleepingComputer, <i>Password recovery tool infects industrial systems with Sality malware</i> , Jul 2022	Reporting on H; affected vendor list	Reports H
O	Dark Reading, coverage of the Dragos MIMICS project	Sality prevalence in ICS environments (1,225 detections). MIMICS dates to the 2017 SANS ICS Summit — historical	Reports Dragos
P	The Fintech Times, LookingGlass bot-infection reporting, Mar 2022	Sector percentages (13% financial services, 11.87% energy). Vendor marketing; methodology and denominator unpublished	Reports LookingGlass

17.5 Precedent, comparison and ethics

REF	SOURCE	VALUE	INDEPENDENCE
J1	CrowdStrike, <i>GameOver Zeus</i> disruption	2014 precedent — peer-list control plus DGA and backend neutralisation	Same vendor as E
J2	CrowdStrike, <i>Inside the Takedown of ZOMBIE SPIDER and the Kelihos Botnet</i>	2017 precedent — peer-list poisoning against unprotected membership information	Same vendor as E
J3	CrowdStrike, <i>Disrupting Glassworm</i> , May 2026	The contrast case. Four parallel C2 channels including blockchain and BitTorrent DHT, all requiring simultaneous disruption	Same vendor as E
Q	CSO Online / Computerworld, <i>Do-it-yourself plan to take down Sality botnet outlined on public mailing list</i> , Mar 2012	Symantec's position that unilateral remediation of third-party machines is legally and ethically impermissible	Independent

17.6 Contemporaneous reporting

REF	SOURCE	VALUE	INDEPENDENCE
G1	Reuters (Raphael Satter, Las Vegas; Anton Zverev, London), <i>Russian cybercrime operation being dismantled after two decades</i> , 1 Sep 2026	Werner quotes; Shadowserver's David Watson on residual risk and possible operator response; the reported DOJ statement of a Russia nexus that does not appear in F	Reports E's claims; the Shadowserver comment is independent
G2	Same Reuters wire, republished	Duplicate of G1 for access	Same wire — not independent corroboration

INDEPENDENCE NOTE — READ BEFORE CITING

Tillmann Werner authors or co-authors sources **B, E and I**. The apparent convergence between the 2013 P2PWNED research and the 2026 operation is therefore substantially **the same researcher agreeing with himself**, not independent corroboration. This is why 6.3 rates the eviction-primitive hypothesis [A, Low]. Similarly, sources **D, D2, J1, J2 and J3** are all CrowdStrike, and **G1/G2** are one wire story. Counting these as separate sources would overstate corroboration; the rule at 1.2(2) applies.

Retrieval note. Source A's original Symantec URL is offline following the Broadcom acquisition; a mirror is available. All other URLs were live as of 2 September 2026.

Prepared from open sources. The Symantec figures are reconstructed as designed exhibits from the technical descriptions in source A, with the original figure numbering preserved for cross-reference. The RSA modulus comparison at 12.1 and the UDP port-range derivation at 14.4 were independently computed and verified during preparation.